南開大學

信息安全综合实验课程实验报告

实验三：WPA 和 WPA2 协议分析

学　　院　密码与网络空间安全学院

专　　业　信息安全、法学双学位班

学　　号　2313815

姓　　名　段俊宇

班　　级　信息安全、法学双学位班

一、实验目的

1. 理解 WPA/WPA2-PSK 协议的基本原理
2. 掌握四次握手过程的详细流程
3. 使用 Wireshark 等工具捕获握手包
4. 分析 EAPOL-Key 帧的结构和字段
5. 探讨 KRACK 等针对握手协议的安全攻击

二、实验原理

1.2 WPA/WPA2 协议基础

1.2.1 从 WEP 到 WPA/WPA2

WEP（Wired Equivalent Privacy）是 IEEE 802.11 标准最初采用的安全协议，但由于设计缺陷，其使用的 24 位 IV（初始化向量）空间过小，且 RC4 密钥流存在统计偏差，导致攻击者可以在短时间内破解密钥。2001 年，WEP 被正式攻破，促使了 WPA 的推出。

WPA（WiFi Protected Access）采用 TKIP（Temporal Key Integrity Protocol）作为临时解决方案，保持了与旧硬件的兼容性。WPA2 则完全取代了 WEP，采用 AES-CCMP 加密，成为目前最广泛使用的 WiFi 安全标准。

1.2.2 WPA/WPA2-PSK 认证模式

- WPA-Enterprise（802.1X）：使用 RADIUS 服务器进行集中认证，适用于企业环境，每个用户有独立的凭证
- WPA-Personal（PSK）：使用预共享密钥，所有用户使用相同的密码，适用于家庭和小型网络

本实验重点关注 WPA/WPA2-PSK 模式，这也是手机热点普遍采用的模式。在 PSK 模式下，所有连接设备共享同一个密码（通常 8-63 个字符），协议通过四次握手过程派生会话密钥，确保每个连接使用独立的加密密钥。

1.2.3 核心密钥体系

WPA/WPA2-PSK 使用分层密钥体系，主要密钥包括：

表 1 WPA/WPA2 密钥体系

密钥名称	全称	用途
PSK	Pre-Shared Key	用户输入的密码，用于生成 PMK
PMK	Pairwise Master Key	从 PSK 派生的主密钥（256 位）
PTK	Pairwise Transient Key	会话密钥，用于单播数据加密
GTK	Group Temporal Key	组密钥，用于广播/组播加密
GMK	Group Master Key	组主密钥，用于生成 GTK

PMK 的生成公式如下：

$$\boldsymbol{PMK = PBKDF2(HMAC-SHA1, PSK, SSID, 4096, 256)}$$

其中 PBKDF2 是密码学密钥派生函数，4096 是迭代次数，256 是输出密钥长度（位）。这种设计通过大量迭代增加暴力破解的难度。

1.3 四次握手协议详解

1.3.1 协议参与者

- Authenticator（认证者）：通常是 AP（接入点）或手机热点，负责控制网络接入
- Supplicant（请求者）：试图接入网络的客户端设备（STA）

1.3.2 握手流程

四次握手的目的是在不直接传输 PMK 的情况下，双方协商生成 PTK 和 GTK。流程如下：

【第一次握手】Authenticator → Supplicant

消息内容：ANonce（Authenticator 生成的随机数） 目的：Supplicant 利用 ANonce 计算 PTK

【第二次握手】Supplicant → Authenticator

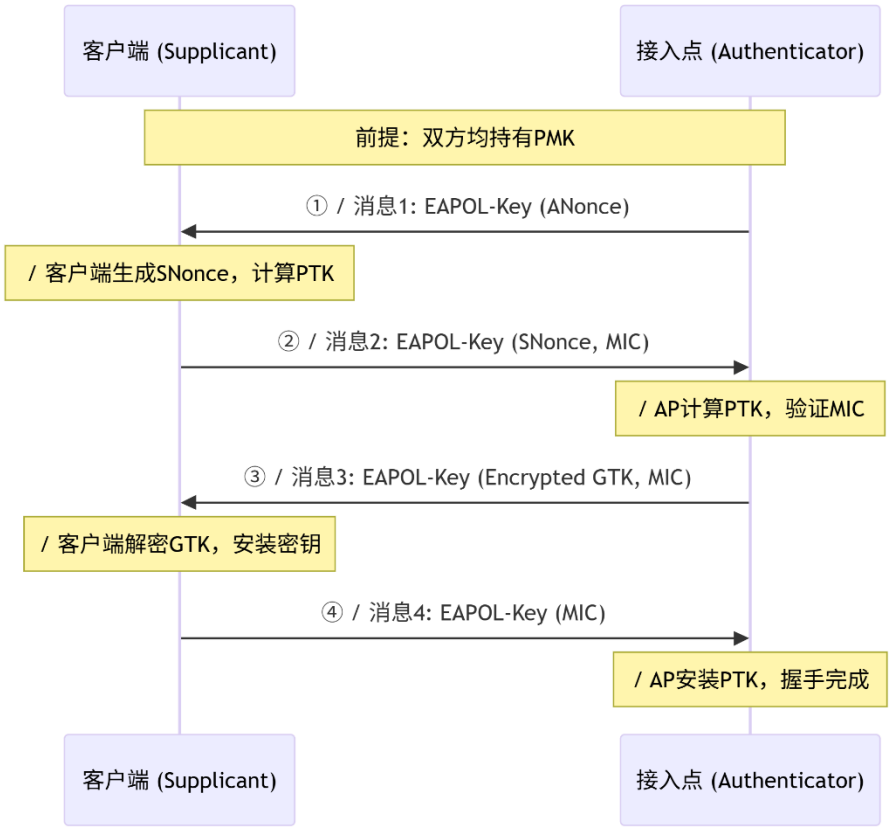
消息内容：SNonce + MIC（消息完整性校验码） 目的：Authenticator 验证 Supplicant 拥有正确的 PMK

【第三次握手】Authenticator → Supplicant

消息内容：GTK（用 PTK 加密）+ MIC 目的：分发组密钥，Supplicant 验证 Authenticator

【第四次握手】Supplicant → Authenticator

消息内容：MIC 目的：确认密钥安装完成



1.3.3 PTK 派生

PTK（Pairwise Transient Key）通过以下公式派生：

PTK = PRF(PMK, “Pairwise key expansion” , min(AA, SA) || max(AA, SA) || min(ANonce, SNonce) || max(ANonce, SNonce))

PTK 长度为 512 位（WPA2）或 384 位（WPA），分为三个部分：

- KCK（Key Confirmation Key，128 位）：用于计算 MIC，验证消息

完整性

- KEK（Key Encryption Key，128 位）：用于加密 GTK 等敏感数据
- TK（Temporal Key，128 位/256 位）：用于加密实际数据流量

1.4 面临的安全威胁

1.4.1 离线字典攻击

由于 PSK 是用户可记忆的密码，通常强度有限。攻击者可以：

捕获握手包：监听并记录四次握手过程

提取关键数据：从握手包中获取 SSID、ANonce、SNonce、MAC 地址和 MIC

离线暴力破解：使用字典或暴力枚举 PSK，计算 PMK 和 PTK，验证 MIC 是否匹配

1.4.2 KRACK 攻击（Key Reinstallation Attack）

2017 年，Mathy Vanhoef 等人发表了 KRACK 攻击，针对四次握手协议的实现缺陷。攻击原理如下：

在第三次握手时，Supplicant 收到加密的 GTK 后会安装 PTK 和 GTK，然后发送第四次握手消息。如果 Authenticator 没有收到第四次握手消息（可能由于丢包或攻击者干扰），会重传第三次握手消息。根据协议，Supplicant 会重新安装已经使用的 PTK，导致 nonce（随机数）计数器重置。

攻击后果：

- Nonce 重用：相同的密钥流被用于加密不同的数据包
- 数据包解密：攻击者可以重放、解密或伪造数据包
- TCP 劫持：可以劫持 TCP 连接，注入恶意数据

1.4.3 其他攻击方式

- Deauthentication 攻击：发送伪造的解除认证帧，迫使客户端重新连接，从而捕获握手包
- Evil Twin 攻击：搭建伪造的 AP，诱骗用户连接，窃取密码
- PMKID 攻击：直接从 AP 获取 PMKID，无需完整握手过程即可进行离线破解

2.2.1 握手包捕获原理

当 WiFi 客户端（如笔记本电脑）首次连接到一个受保护的 WiFi 网络（如

手机热点）时，必须完成四次握手过程以协商加密密钥。这个过程会产生 4 个 EAPOL-Key 帧，使用抓包工具在监控模式下可以捕获这些帧。

捕获握手包的关键时机：

- **初始连接：**客户端首次输入密码连接热点时
- **重新连接：**客户端从休眠唤醒或信号恢复时
- **强制重连：**通过发送 Deauth 帧迫使客户端重新认证

2.2.2 EAPOL-Key 帧结构

EAPOL-Key 帧是四次握手的载体，以 WPA2-PSK 为例，主要字段包括：

表 2 EAPOL-Key 帧主要字段

字段	长度	说明
Key Information	2 字节	密钥描述符类型、密钥索引等标志位
Key Length	2 字节	密钥长度
Replay Counter	8 字节	重放计数器，防止重放攻击
Nonce	32 字节	随机数（ANonce 或 SNonce）
Key IV	16 字节	初始化向量
Key RSC	8 字节	接收序列计数器
Key MIC	16 字节	消息完整性校验码
Key Data Length	2 字节	密钥数据长度
Key Data	变长	加密的 GTK 等信息

三、实验环境

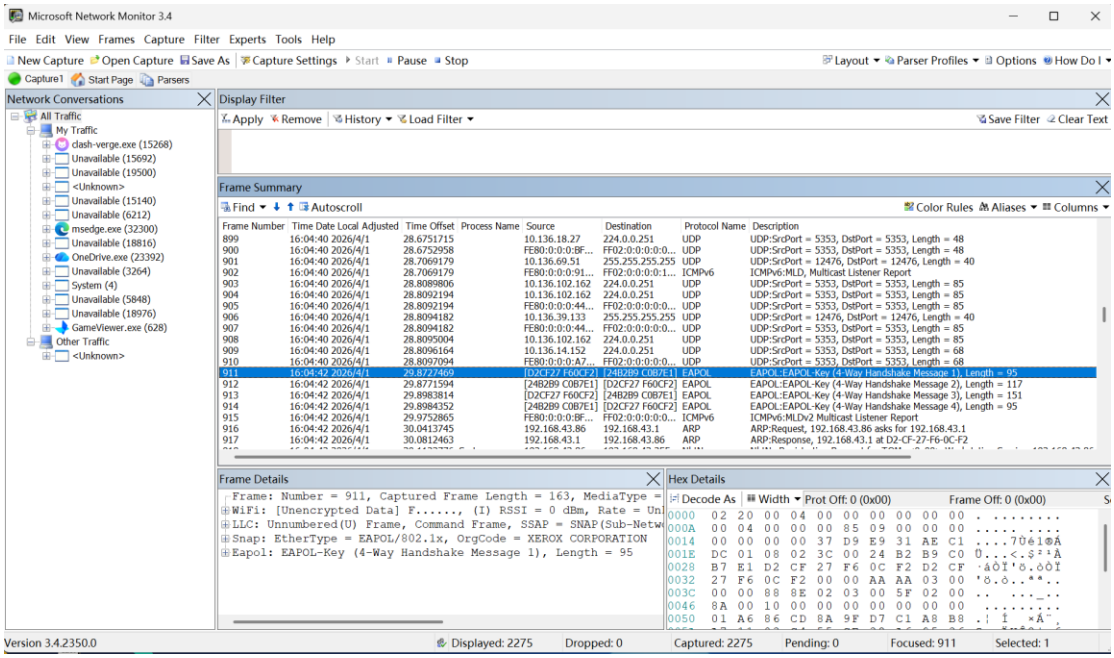
Kali Linux 操作系统(虚拟机) + Windows11 操作系统

- Wireshark
- Microsoft Network Monitor
- Hashcat

四、实验过程

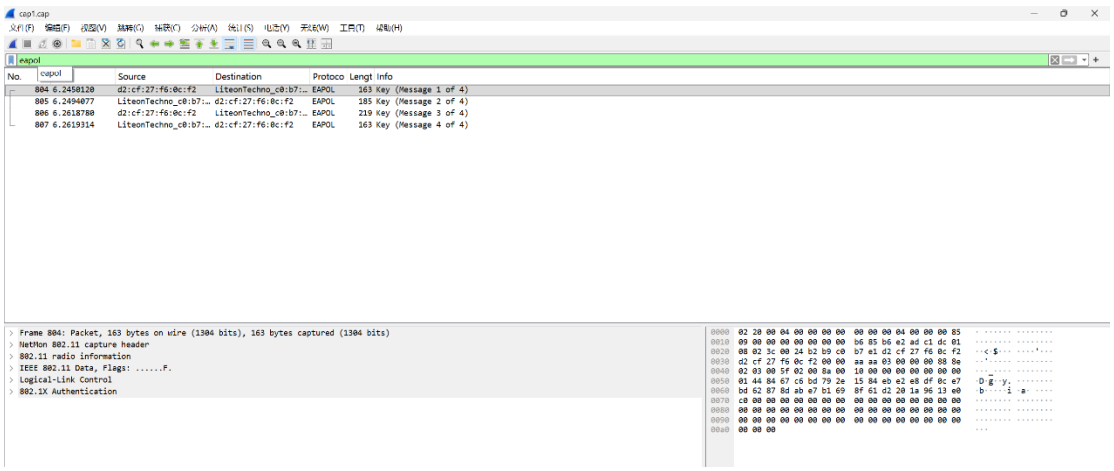
1. 环境配置及数据包捕获

本次实验中需要使用 Wireshark 和 Microsoft Network Monitor，首先下载并安装这些工具，然后打开 Microsoft Network Monitor，点击开始捕获。随后连接手机热点，连接成功后点击停止，此时搜索 eapol 应该能看到四次握手的数据包，这样就成功捕获数据包。



2、 四次握手分析

使用 wireshark 打开已经保存的数据包捕获文件，并设置 eapol 过滤器，如下所示：



（1） AP 向客户端

通过查看数据包信息可以发现，第一次握手中 ACK 标志被设置为 1，表示需要客户端确认；Replay Counter 被设置为 1，表示这是第一次握手；Nonce 是随机生成的，MIC 为 0，这是为了让客户端计算自己的 PTK。

```
802.1X Authentication
    Version: 802.1X-2004 (2)
    Type: Key (3)
    Length: 95
    Key Descriptor Type: EAPOL RSN Key (2)
    [Message number: 1]
    Key Information: 0x008a
        .... .... .... .010 = Key Descriptor Version: AES Cipher, HMAC-SHA1 MIC (2)
        .... .... .... 1... = Key Type: Pairwise Key
        .... .... ..00 .... = Key Index: 0
        .... .... .0.. .... = Install: Not set
        .... .... 1... .... = Key ACK: Set
        .... ...0 .... .... = Key MIC: Not set
        .... ..0. .... .... = Secure: Not set
        .... .0.. .... .... = Error: Not set
        .... 0... .... .... = Request: Not set
        ...0 .... .... .... = Encrypted Key Data: Not set
        ..0. .... .... .... = SMK Message: Not set
    Key Length: 16
    Replay Counter: 1
    WPA Key Nonce: 448467c6bd792e1584ebe2e8df0ce7bd62878dabe7b1698f61d2201a9613e0c0
    Key IV: 00000000000000000000000000000000
    WPA Key RSC: 0000000000000000
    WPA Key ID: 0000000000000000
    WPA Key MIC: 00000000000000000000000000000000
    WPA Key Data Length: 0
```

（2） 客户端向 AP

在第二次握手中，客户端将自己的 Nonce 发送给 AP，并使用 PTK 中的 KCK 对整个消息计算完整性校验码，这就是 MIC，因此 MIC 标志位被设置为 1。AP 通过验证 MIC 就可以确认客户端是否拥有正确的 PMK。

```
802.1X Authentication
    Version: 802.1X-2001 (1)
    Type: Key (3)
    Length: 117
    Key Descriptor Type: EAPOL RSN Key (2)
    [Message number: 2]
    Key Information: 0x010a
        .... .... .... .010 = Key Descriptor Version: AES Cipher, HMAC-SHA1 MIC (2)
        .... .... .... 1... = Key Type: Pairwise Key
        .... .... ..00 .... = Key Index: 0
        .... .... .0.. .... = Install: Not set
        .... .... 0... .... = Key ACK: Not set
        .... ...1 .... .... = Key MIC: Set
        .... ..0. .... .... = Secure: Not set
        .... .0.. .... .... = Error: Not set
        .... 0... .... .... = Request: Not set
        ...0 .... .... .... = Encrypted Key Data: Not set
        ..0. .... .... .... = SMK Message: Not set
    Key Length: 0
    Replay Counter: 1
    WPA Key Nonce: 858d8388f6eede78ed36322af8e68388e14dc9ee4eaa404af789e23557baa15e
    Key IV: 00000000000000000000000000000000
    WPA Key RSC: 0000000000000000
    WPA Key ID: 0000000000000000
    WPA Key MIC: f6529928fa1b87a6b9082cb1639330b1
    WPA Key Data Length: 22
    WPA Key Data: 30140100000fac040100000fac040100000fac020000
    Tag: RSN Information
        Tag Number: RSN Information (48)
        Tag length: 20
        RSN Version: 1
        Group Cipher Suite: 00:0f:ac (Ieee 802.11) AES (CCM)
        Pairwise Cipher Suite Count: 1
        Pairwise Cipher Suite List 00:0f:ac (Ieee 802.11) AES (CCM)
        Auth Key Management (AKM) Suite Count: 1
        Auth Key Management (AKM) List 00:0f:ac (Ieee 802.11) PSK
        RSN Capabilities: 0x0000
```

（3） AP 向客户端

在第三次握手中，Replay Counter 递增为 2，表示进入下一阶段。

Install 标志位被设置为 1，这是 AP 指示客户端安装 PTK。同时 MIC 和 ACK 标志也被设置为 1，用来让客户端验证消息未被篡改并确认。在这个数据包的 WPA Key Data 字段包含了用 PTK 中的 KEK 加密的 GTK，也就是 AP 向客户端发送的加密分组密钥。

```
802.1X Authentication
    Version: 802.1X-2004 (2)
    Type: Key (3)
    Length: 183
    Key Descriptor Type: EAPOL RSN Key (2)
    [Message number: 3]
    Key Information: 0x13ca
        .... .... .... .010 = Key Descriptor Version: AES Cipher, HMAC-SHA1 MIC (2)
        .... .... .... 1... = Key Type: Pairwise Key
        .... .... ..00 .... = Key Index: 0
        .... .... .1.. .... = Install: Set
        .... .... 1... .... = Key ACK: Set
        .... ...1 .... .... = Key MIC: Set
        .... ..1. .... .... = Secure: Set
        .... .0.. .... .... = Error: Not set
        .... 0... .... .... = Request: Not set
        ...1 .... .... .... = Encrypted Key Data: Set
        ..0. .... .... .... = SMK Message: Not set
    Key Length: 16
    Replay Counter: 2
    WPA Key Nonce: 4eaea715b9a274aba96eec1a009ad7a834727e6a0a19e786b8663d6e659063bf
    Key IV: 00000000000000000000000000000000
    WPA Key RSC: 0000000000000000
    WPA Key ID: 0000000000000000
    WPA Key MIC: 9986bfbc5e0748e09783644980168833
    WPA Key Data Length: 88
    WPA Key Data: 260ccaef996e7da0af21ccd277003a5128cbd18716e38ed4aae31266ef253be4f04a2211fa8139f977f95f97fa13b67fe1625e681ecbac57299dfcdb90cbae0b5…
```

（4） 客户端向 AP

在第四次握手中，客户端发送给 AP 确认密钥已成功安装。MIC 用于验证消息完整性，Replay Counter 为 2 与第三次握手匹配。AP 收到并验证 MIC 后，开始加密通信。这样就完成了 WPA2 的四次握手！

```
802.1X Authentication
    Version: 802.1X-2001 (1)
    Type: Key (3)
    Length: 95
    Key Descriptor Type: EAPOL RSN Key (2)
    [Message number: 4]
    Key Information: 0x030a
        .... .... .... .010 = Key Descriptor Version: AES Cipher, HMAC-SHA1 MIC (2)
        .... .... .... 1... = Key Type: Pairwise Key
        .... .... ..00 .... = Key Index: 0
        .... .... .0.. .... = Install: Not set
        .... .... 0... .... = Key ACK: Not set
        .... ...1 .... .... = Key MIC: Set
        .... ..1. .... .... = Secure: Set
        .... .0.. .... .... = Error: Not set
        .... 0... .... .... = Request: Not set
        ...0 .... .... .... = Encrypted Key Data: Not set
        ..0. .... .... .... = SMK Message: Not set
    Key Length: 0
    Replay Counter: 2
    WPA Key Nonce: 0000000000000000000000000000000000000000000000000000000000000000
    Key IV: 00000000000000000000000000000000
    WPA Key RSC: 0000000000000000
    WPA Key ID: 0000000000000000
    WPA Key MIC: eaba5a42def6f4c16043d803381de1b3
    WPA Key Data Length: 0
```

3、离线字典攻击

本次实验我使用 hashcat 来实施离线字典攻击，首先需要从 hashcat 官网下载压缩包并解压，可以按照 hashcat 官网的 wiki 的流程进行实

验。接着需要将已经捕获的.cap 文件转换为 hashcat 能够处理的.hc22000 文件，通过配套工具（https://hashcat.net/cap2hashcat）可以实现。然后我下载了官网提供的 crack.txt.gz（https://wpa-sec.stanev.org/dict/cracked.txt.gz）字典，这里面包含了单词列表，用于暴力破解。

现在正式开始破解，首先尝试简单密码的数据包，命令为 hashcat -m 22000 C:\Users\LIANXIANG\Desktop\1736817_1775109628.hc22000 cracked.txt.gz，运行后发现很快就得到了结果，如下所示：

```
Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 63
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Slow-Hash-SIMD-LOOP

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory allocated for this attack: 992 MB (4873 MB free)

Dictionary cache built:
* Filename..: cracked.txt.gz
* Passwords.: 760479
* Bytes.....: 8563034
* Keyspace..: 760479
* Runtime...: 0 secs

a2ee93fc1a9427295183d38a0cbe50e6:3e1ccea31e51:cc15319f914c:dengcongyi:159357456

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 22000 (WPA-PBKDF2-PMKID+EAPOL)
Hash.Target......: C:\Users\LIANXIANG\Desktop\1736817_1775109628.hc22000
Time.Started.....: Thu Apr 02 14:10:41 2026 (1 sec)
Time.Estimated...: Thu Apr 02 14:10:42 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 8-63 bytes)
Guess.Base.......: File (cracked.txt.gz)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:     9675 H/s (7.73ms) @ Accel:3 Loops:256 Thr:64 Vec:1
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 3073/760479 (0.40%)
Rejected.........: 1/3073 (0.03%)
Restore.Point....: 1537/760479 (0.20%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: happy123 -> happyday

Started: Thu Apr 02 14:10:08 2026
Stopped: Thu Apr 02 14:10:43 2026

D:\hashcat-7.1.2>hashcat -m 22000 C:\Users\LIANXIANG\Desktop\1736817_1775109628.hc22000 cracked.txt.gz --show
a2ee93fc1a9427295183d38a0cbe50e6:3e1ccea31e51:cc15319f914c:dengcongyi:159357456
```

最后得到的 wifi 热点 SSID 是 dencongyi，密码是 159357456。继续尝试复杂密码的数据包，运行后发现没有爆破出密码：

```
D:\hashcat-7.1.2>hashcat -m 22000 C:\Users\LIANXIANG\Desktop\1736819_1775109648.hc22000 cracked.txt.gz
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 ) - Platform #1 [Intel(R) Corporation]
==================================================================
* Device #01: Intel(R) RaptorLake-S Mobile Graphics Controller, 3560/7120 MB (1780 MB allocatable), 8MCU

Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 63
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Slow-Hash-SIMD-LOOP

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory allocated for this attack: 992 MB (5198 MB free)

Dictionary cache hit:
* Filename..: cracked.txt.gz
* Passwords.: 760479
* Bytes.....: 3583764
* Keyspace..: 760479

Approaching final keyspace - workload adjusted.

Session..........: hashcat
Status...........: Exhausted
Hash.Mode........: 22000 (WPA-PBKDF2-PMKID+EAPOL)
Hash.Target......: C:\Users\LIANXIANG\Desktop\1736819_1775109648.hc22000
Time.Started.....: Thu Apr 02 14:16:55 2026 (1 min, 36 secs)
Time.Estimated...: Thu Apr 02 14:18:31 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 8-63 bytes)
Guess.Base.......: File (cracked.txt.gz)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:     7992 H/s (7.03ms) @ Accel:3 Loops:256 Thr:64 Vec:1
Recovered........: 0/1 (0.00%) Digests (total), 0/1 (0.00%) Digests (new)
Progress.........: 760479/760479 (100.00%)
Rejected.........: 24/760479 (0.00%)
Restore.Point....: 760479/760479 (100.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 81405862 -> 81499793
```

从运行结果可以看出，已经遍历了字典中所有的密码，但是没有得到对应的结果。说明强密码较弱密码更加安全，因此在设置密码时应当设置为字母、数字及特殊符号的组合，并且位数不能少于 8 位，这样才能保证安全性。

五、实验结论及心得体会

本次实验通过抓包并分析数据包内容，我了解了 WPA/WPA2 协议四次握手的基本流程以及传输的字段。由于 Microsoft Network Monitor 捕获的.cap 文件格式较为特殊，没有办法转为.hc22000 文件进行爆破，尝试了 hashcat 官网的许多办法，并与同学、老师交流后，仍然无法实现离线字典攻击，最终使用老师统一提供的数据包文件完成了离线字典攻击实验。通过对弱密码和强密码的爆破，让我了解到了密码长度及复杂性的重要性，只有强度高的密码才能确保正常通信的安全性。